



PSYBER

TECHNOLOGIES

Adversary-Informed Security

Red-Team Engagement Proposal

Prepared for the British Library · CISO Briefing

C S T 8 8 0 7 · P E N E T R A T I O N T E S T I N G · G R O U P 3

June 2026 · Algonquin College



Who we are, and who is in the room

PSYBER TECHNOLOGIES AT A GLANCE

Headquarters	Ottawa, Canada — UK partner office, London
Focus	Adversary emulation, red-team engagements, purple-team uplift
Industries	Public sector, cultural institutions, financial services
Certifications	CREST CRT, OSCP, OSEP, GPEN, GXPN held across the consulting roster
Memberships	FIRST · CREST · CyberScotland Partnership

TODAY'S DELEGATION

MZ **Mohammad Zghoul**
Chief Executive Officer

MP **Marc-Andre Poulin**
Role — to be confirmed

MA **Mohammed Alnajeh**
Role — to be confirmed

KZ **Kouraich Zemzmi**
Role — to be confirmed

CS **Chirag Sharma**
Role — to be confirmed



The October 2023 attack, in five public facts



Sources: British Library, *Learning Lessons from the Cyber-Attack* (08 March 2024); BBC News (31 Oct 2023); NCSC commentary; Rhysida leak-site disclosures.



The bill the Library is still paying

~600 GB

of internal data exfiltrated and leaked

£6–7 m

estimated recovery cost (~40% of reserves)

9+ mo.

of degraded reading-room and catalogue services

~470k

user accounts forced to reset credentials

“

The financial impact remains significant — the Library will draw on around 40% of its reserves to fund the recovery — but the human and reputational impact is harder to quantify and longer to repair.

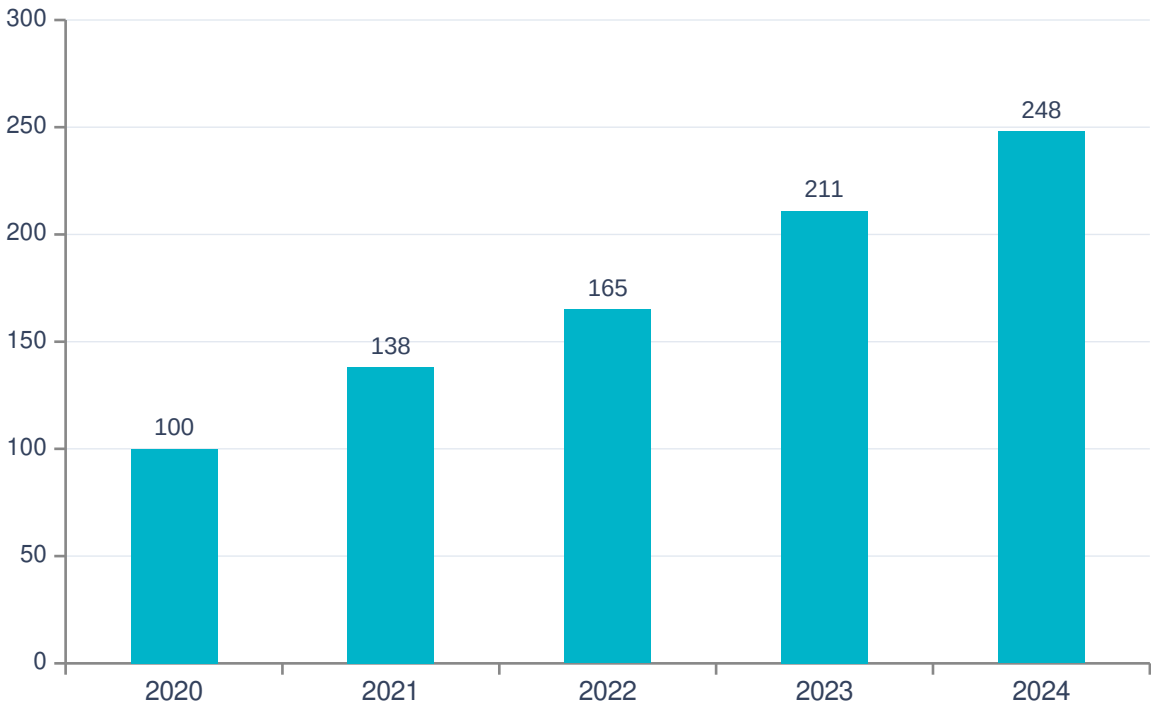
— Sir Roly Keating, Chief Executive, British Library (paraphrased from public statements, March 2024)

Sources: British Library Lessons-Learned report (Mar 2024); Financial Times reporting (Jan–Mar 2024); BBC News coverage.



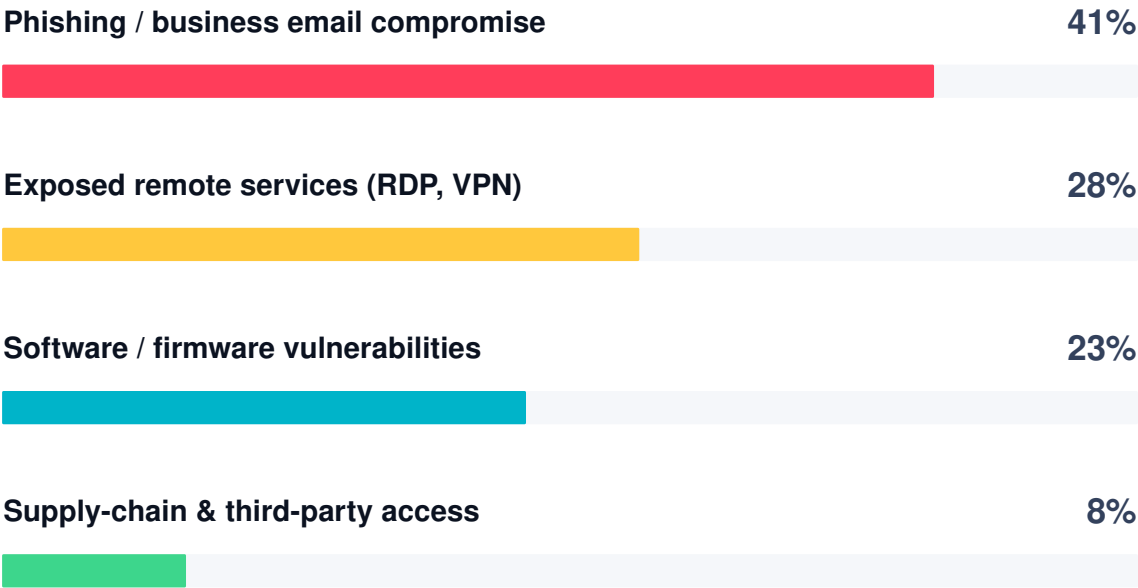
The curve is steepening — and the doors are familiar

RANSOMWARE ATTACKS ON UK ORGANISATIONS



Indexed to 2020 = 100 · Composite of NCSC, ENISA, and ICO public reporting.

TOP RANSOMWARE ENTRY POINTS (2024)



Sources: Verizon DBIR 2024; ENISA Threat Landscape 2024; NCSC Annual Review 2024; ICO ransomware advisories.



Three engagements we draw the most lessons from

NATIONAL ARCHIVE

Post-incident hardening, EU member state

Scope: External, internal, social-engineering, AD attack-path mapping

- Identified an exposed legacy authentication portal previously assumed isolated
- Mapped a 4-hop path from a contractor laptop to Domain-Admin equivalent
- Closed nine critical findings within ninety days of report delivery

MUNICIPAL SERVICES

Annual red-team retainer, Tier-1 Canadian city

Scope: Full-scope adversary emulation, payment gateway, citizen-portal review

- Demonstrated full takeover of an over-permissioned CI/CD runner
- Surfaced eleven previously unknown publicly exposed S3 buckets
- Reduced MTTD (mean-time-to-detect) from 14 days to under 4 hours

RESEARCH UNIVERSITY

Phishing & identity-perimeter assessment

Scope: Targeted social-engineering, MFA fatigue, conditional-access review

- Achieved valid Microsoft 365 access on 38 of 200 simulated targets
- Bypassed two of three legacy MFA configurations within four hours
- Drove adoption of phishing-resistant MFA across 12k accounts

Engagement details have been anonymised; references available under NDA on request.



Mapped to the frameworks you already report against

UK GDPR

Article 32 — security of processing; documents technical & organisational measures.

NIS Regulations 2018

Sector-specific cyber-security duties for essential & digital services.

ISO/IEC 27001:2022

Annex A control validation — A.5 policies, A.8 asset mgmt, A.12 ops, A.14 dev/test.

Cyber Essentials Plus

External + on-site hands-on testing; matches the five technical controls.

NCSC CAF

Cyber Assessment Framework — outcomes B (Defending against attack) & C (Detecting).

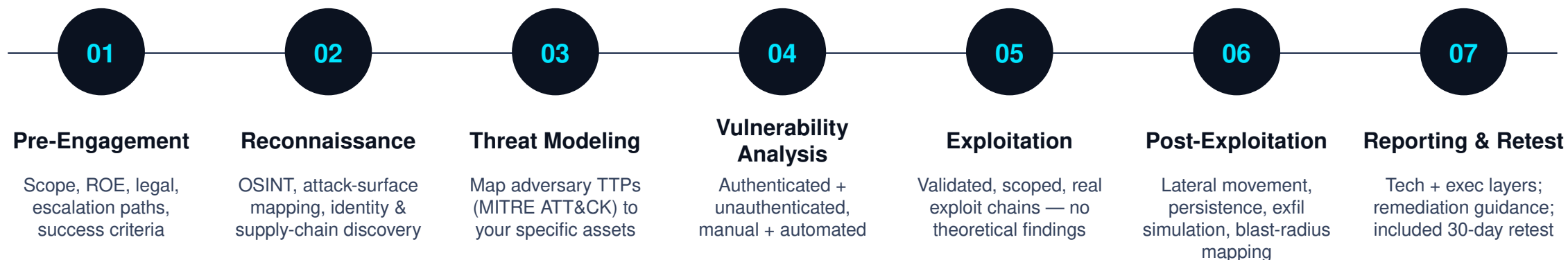
PCI DSS v4.0

Requirement 11.4 — internal & external penetration testing; segmentation validation.

Every finding we deliver is tagged with the relevant control reference so your assurance team can ingest the report directly.



Seven phases, aligned to PTES & NIST SP 800-115



ALIGNED TO

PTES · NIST SP 800-115 · OWASP WSTG · OSSTMM · MITRE ATT&CK v15



Six weeks, scoped around your actual estate

PROPOSED SCOPE

- Public-facing perimeter (web, APIs, mail, DNS, edge appliances)
- Identity & access — Entra ID, federated SSO, conditional access, MFA
- Reader-facing systems — catalogue, account portal, payments
- Reading-room infrastructure — WiFi, printing, public terminals
- Internal Active Directory & legacy authentication portals
- CI/CD, source repos, build runners, and admin tooling
- OT / building-management interfaces where IT-OT bridges exist
- Targeted social-engineering against staff with privileged access

6 - WEEK TIMELINE



All exploitation is performed under signed Rules of Engagement with named senior escalation contacts on both sides.



Open-source, commercial, proprietary — calibrated to risk

RECONNAISSANCE

Recon-ng · Amass · Shodan ·
Censys · Maltego · SpiderFoot

VULNERABILITY

Nessus Pro · Nuclei · Burp Suite
Pro · OWASP ZAP · Nikto · wpscan

EXPLOITATION

Metasploit Framework · Cobalt Strike
· Sliver C2 · Impacket ·
responder · evil-winrm

POST-EXPLOIT & AD

BloodHound CE · Rubeus · Mimikatz
· CrackMapExec · SharpHound ·
Certify

CLOUD & IDENTITY

ROADtools (Entra) · ScoutSuite ·
PingCastle · Prowler · AzureHound
· AADInternals

REPORTING & EVIDENCE

Dradis Pro · PlexTrac · MITRE
Caldera · Atomic Red Team ·
internal: Psy-Lens platform

All tool usage is documented, hash-pinned where applicable, and de-conflicted with your SOC in pre-engagement.



What you receive, and what changes

WHAT YOU RECEIVE

- Executive briefing report — board-ready, plain English
- Technical findings register — every finding evidenced, repro steps included
- MITRE ATT&CK mapping & detection-content recommendations
- Compliance cross-walk (ISO 27001, CAF, Cyber Essentials Plus)
- Remediation roadmap with effort estimates and owner suggestions
- Free 30-day retest of all critical & high findings

IMMEDIATE (30 DAYS)

- Validated inventory of internet-exposed assets
- Confirmed list of exploitable identity & MFA weaknesses
- Closure plan for any externally exploitable critical findings
- SOC playbook updates against attempted exploit paths
- Tabletop-ready scenario script for next exec exercise

LONG-TERM (12 MONTHS)

- Measurable reduction in MTTD and MTTR
- Demonstrable posture improvement against CAF outcomes B & C
- Stronger defensible position with regulators (ICO, NCSC)
- Restored confidence with readers, researchers, & rights-holders
- A documented baseline against which to plan year-2 testing

Next Steps

If today's conversation moves us forward, here is the sequence we propose:

01

Signed NDA

Mutual NDA executed within 2 business days.

02

Scoping Workshop

90-minute working session with your team to lock scope & ROE.

03

Statement of Work

Fixed-fee SOW with milestones, deliverables, and named consultants.

04

Kickoff

Engagement begins within 14 days of SOW signature.

Questions & Discussion

We've reserved the remainder of this meeting for your questions.

